



КАК АТАКУЮТ АНАЛИТИКОВ ДАННЫХ

Offensive cybersecurity для аналитиков данных

ПОЧЕМУ АНАЛИТИК — ЛАКОМАЯ ЦЕЛЬ

ДОСТУП К ДАННЫМ

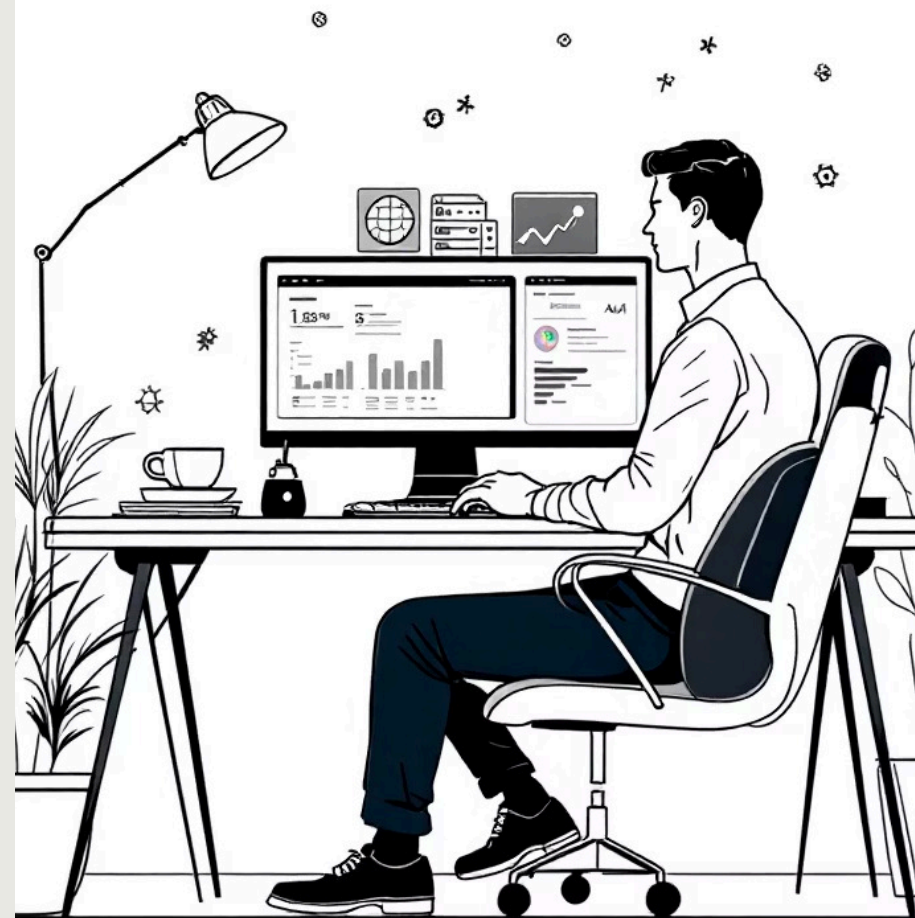
Production БД, финансовые отчёты,
клиентские данные

ДОВЕРЕННАЯ СРЕДА

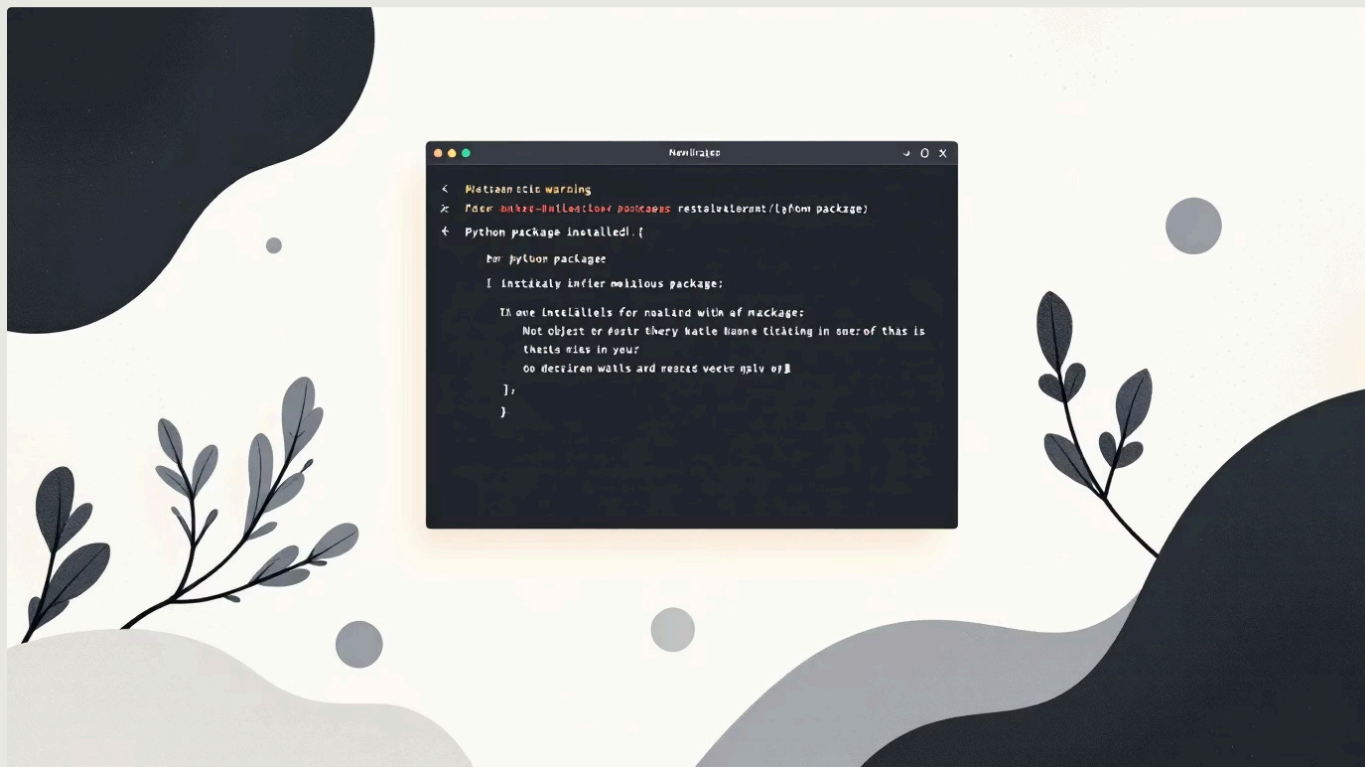
Сценарии и скрипты запускаются
без проверок

СЛАБЫЙ КОНТРОЛЬ

Безопасность ИБ редко смотрит в сторону ML-пайплайнов



АТАКИ ЧЕРЕЗ PYTHON-БИБЛИОТЕКИ



КАК ЭТО РАБОТАЕТ

- Атакующий публикует пакет с именем, похожим на популярный: `pandes`, `scikit-learn`
- **Dependency confusion** — подмена внутреннего пакета компании публичным вредоносным
- Код выполняется при `pip install` — до того, как аналитик что-либо запустил

ВРЕДОНОСНЫЙ КОД В ML-ПАЙПЛАЙНЕ



Достаточно одной вспомогательной функции — и код молча отправляет данные наружу при каждом запуске модели.

РИСКИ AI-ИНСТРУМЕНТОВ

УТЕЧКА ЧЕРЕЗ LLM

Данные, отправленные в ChatGPT или Copilot, могут попасть во внешние обучающие датасеты

PROMPT INJECTION

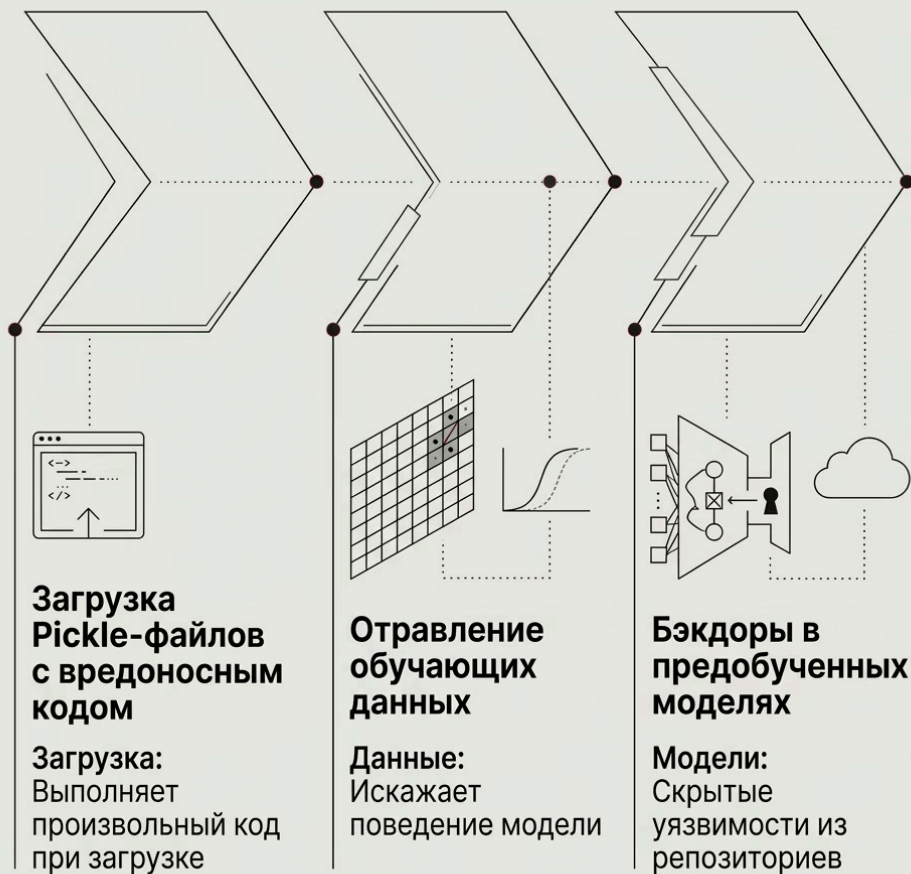
Вредоносные инструкции, встроенные в документы или датасеты, управляют поведением AI

ВНЕШНИЕ СЕРВИСЫ

Плагины и API без аудита — прямой канал для чувствительных данных



ОПАСНОСТЬ ML-МОДЕЛЕЙ И ДАТАСЕТОВ



РЕАЛЬНЫЙ СЦЕНАРИЙ

`pickle.load(model.pkl)` – это выполнение произвольного кода.
Модель с Hugging Face может содержать бэкдор.

- ❏ Никогда не загружайте .pkl-файлы из непроверенных источников

АРХИТЕКТУРА, КОТОРАЯ ПОМОГАЕТ АТАКУЮЩЕМУ



ПРЯМОЙ ДОСТУП К **PROD**

Аналитик читает боевую БД напрямую — без изоляции



ДАННЫЕ НА НОУТБУКЕ

CSV с клиентами в папке Downloads — мечта атакующего



ОБЩИЕ НОУТБУКИ

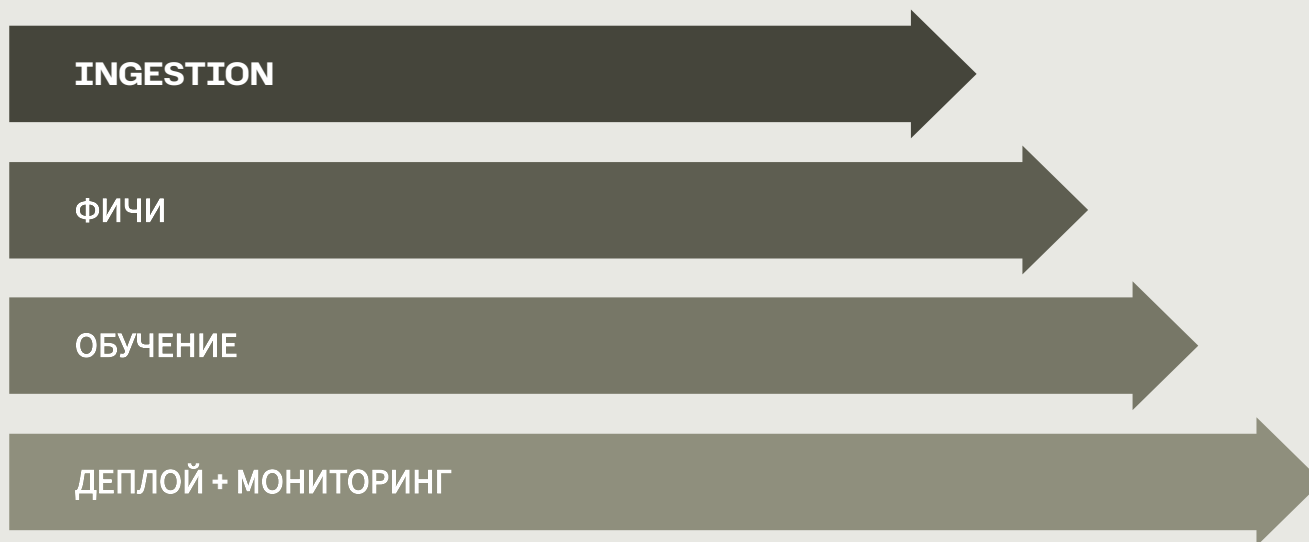
Один Jupyter на команду — компрометация одного = доступ всех



НЕТ КОНТРОЛЯ ВЕРСИЙ

Изменения в коде невозможно отследить — идеально для скрытой атаки

КАК АТАКУЮЩИЙ ВИДИТ ВАШ DATA PIPELINE



ГДЕ ЗАКРЕПИТЬСЯ ПРОЩЕ
ВСЕГО

- 1** **Ingestion** — подмена источника данных
- 2** **Feature store** — отравление признаков
- 3** **Model registry** — замена модели

ПРАКТИЧЕСКИЕ ПРАВИЛА ДЛЯ АНАЛИТИКА



ПРОВЕРЯЙ ЗАВИСИМОСТИ

Используй `pip-audit` и `safety`. Фиксируй версии в `requirements.txt`



НЕ ТАЩИ **PROD**-ДАННЫЕ ЛОКАЛЬНО

Работай с анонимизированными или синтетическими датасетами



CODE REVIEW ДЛЯ НОУТБУКОВ

Используй `nbdime` и Git. Ревьюй изменения перед запуском



ОСТОРОЖНО С **AI**-СЕРВИСАМИ

Не вставляй реальные данные в ChatGPT, Copilot или внешние API



АНАЛИТИК – ЧАСТЬ ПЕРИМЕТРА БЕЗОПАСНОСТИ

**АТАКУЮЩИЙ ИДЁТ ТУДА,
ГДЕ ДАННЫЕ**

А данные – у аналитиков

**БЕЗОПАСНОСТЬ =
ДОСТОВЕРНОСТЬ
МОДЕЛЕЙ**

Скомпрометированный пайплайн –
неверные решения бизнеса

ПРОСТЫЕ ПРИВЫЧКИ МЕНЯЮТ ВСЁ

Не нужно быть ИБ-экспертом – нужно думать как атакующий